

Unconventional Initial Access Vectors Pt. 3

 seccore.at/blog/iavpt3

Benjamin Floriani, Patrick Pongratz

December 22, 2025



If you haven't already, make sure to read the first two parts of our blog series about unconventional initial access vectors:

- [Unconventional Initial Access Vectors Pt. 1](#)
- [Unconventional Initial Access Vectors Pt. 2](#)

Wrapping everything up

In this blog series, we demonstrated how unconventional initial access vectors can be used to compromise modern hybrid environments that are protected by MFA and Conditional Access policies. We also showed how persistence can be established and how lateral movement onto on premise systems can be achieved. The main idea of our research was to show that even modern security measures can be bypassed with enough creativity. But we are not here to just point out problems, the real goal is helping you to defend against real-world attacks like these.

So we compiled a list of useful mitigations that can improve your general security posture, while not just focusing on the specific attack vectors we demonstrated in this blog series.

Conditional Access Policies

Even though we were able to bypass several Conditional Access Policies, that does not mean they are not effective. What we were able to bypass are relatively simple policies

that are built-in to Entra-ID. However, many organizations never implement more complex policies that are specific to their needs. Without further protections, a phished Entra-ID account is a big risk to all applications that are connected to it. This not only includes MS Teams, Outlook, SharePoint, OneDrive etc., but also third-party applications that use Entra-ID for authentication. We recommend asking the following questions when reviewing and improving your Conditional Access policies:

- **Do all accounts have MFA enforced?**
 - Even though with a good phishing backend, MFA can be bypassed, it still adds a significant layer of security.
 - All accounts should have MFA enforced, especially privileged accounts.
- **Are there any high-privilege accounts that should have stricter policies than regular users?**
 - Too many MFA prompts can annoy end-users, but high-privilege accounts need more protection.
 - Phishing-resistant MFA methods like FIDO2 security keys should be enforced for these accounts.
- **Are there any applications that should have their own specific policies?**
 - Some applications are more sensitive than others (VPN, admin portals, terminal servers etc.).
 - Application-specific policies can be implemented to model different risk levels.
- **How do users register new devices and MFA methods?**
 - If this can be done from any device or location, this can be abused to gain persistence.
 - Sensitive operations should be restricted to compliant devices or trusted locations.
- **Are there any risky sign-in detections that should trigger additional challenges or block access?**
 - Entra-ID can detect risky sign-ins based on various factors (impossible travel, unfamiliar locations, anonymous IPs etc.).
 - These detections should be used to trigger additional challenges or block access entirely.

User Awareness Training

Awareness has been an important part of a security strategy for a long time. However, many attacks and phishing campaigns are becoming more sophisticated, and the rise of GenAI makes it even easier to create convincing phishing content. Therefore, training users on specific examples has become more and more ineffective. Instead, we recommend the following approach:

- **Focus on general techniques.**
 - Teach users about the techniques attackers use (social engineering, urgency, authority etc.).
 - Help them understand the psychology behind phishing attacks.
- **Encourage a security mindset.**
 - Questioning unexpected requests and reporting suspicious activity should be part of the company culture from top to bottom.
 - Reward users for reporting potential threats.
- **Regularly update training content.**
 - The rise of GenAI means that attackers have access to extremely powerful tools (Deepfakes, automated OSINT for phishing, etc.).
 - Users need to be aware of what is currently possible. Attackers can clone voices and even video calls, and inexperienced users might not be able to tell the difference.

In a hybrid environment, protect both cloud and on-premise

If you are currently utilizing a hybrid environment with both cloud and on-premise systems, both need to be properly secured. Attackers can exploit weaknesses in either environment to gain access to the entire network and jump between those systems.

- **Cloud is not secure by default.**
 - Many organisations assume that cloud providers are responsible for security, but this is not the case.
 - Make sure to properly configure and monitor your cloud environment, and follow best practices for identity and access management.
- **Consider cloud infrastructure in an internal penetration test.**
 - Many internal penetration tests focus on on-premise systems, but cloud infrastructure is often tightly connected to the internal network.
 - If you are relying on a hybrid environment, make sure that your penetration tests cover both environments.
- **To EDR or not to EDR?**
 - Endpoint Detection and Response (EDR) solutions provide valuable monitoring and detection capabilities for endpoints such as laptops or workstations.
 - However, many attacks nowadays target cloud accounts directly, bypassing those endpoints entirely.
 - Do not solely rely on EDRs for security, they cannot protect what they cannot see!

Want to see our research and how your company reacts to real-world attacks in action?

[Contact us for a free initial consultation!](#)